Walking An Application

Mục lục

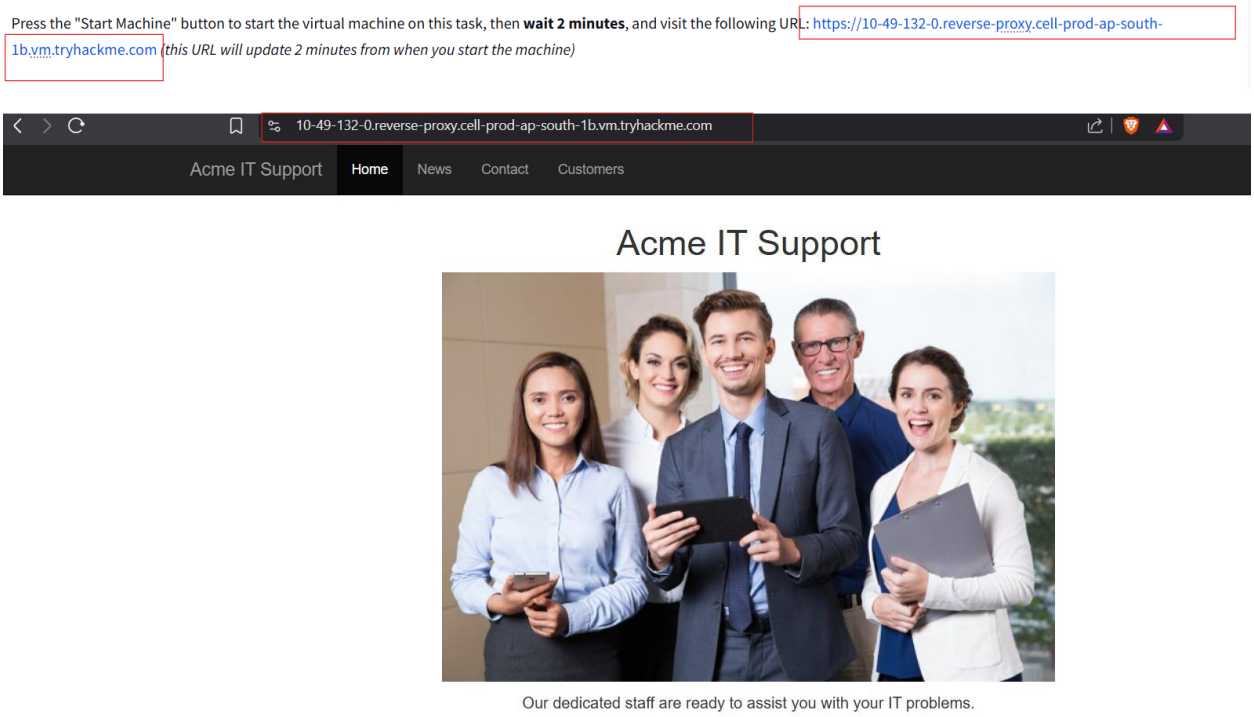
1. Khám phá trang web (Exploring the website) 2
2. Xem mã nguồn (viewing the page source) 3
3. Developer Tools – Inspector 4
4. Developer Tools – Debugger 9
5. Developer Tools – Network 11

Trong bài học này, chúng ta sẽ học cách tự mình kiểm tra các vấn đề bảo mật của một ứng dụng web chỉ bằng các công cụ được tích hợp sẵn trong trình duyệt.

Một số công cụ được tích hợp sẵn trong trình duyệt mà chúng ta sẽ sử dụng trong suốt bài học này:

- Xem mã nguồn (view source): sử dụng trình duyệt để xem mã nguồn dễ đọc của một trang web.
- Kiểm tra (inspector): học cách kiểm tra các phần tử trang và thực hiện các thay đổi để xem các nội dung thường bị chặn.
- Gỡ lỗi (debugger): kiểm tra và điều khiển luồng javascript của một trang.
- Mạng (network): xem tất cả các yêu cầu mạng mà một trang thực hiện.

Tôi sẽ sử dụng 1 trang web được xây dựng sẵn trong bài thực hành này của tryhackme:



1. Khám phá trang web (Exploring the website)

- Với tư cách là một pentester, vai trò của chúng ta khi xem một trang web là hoặc ứng dụng web là phát hiện các tính năng có khả năng dễ bị tấn công và cố gắng khai thác chúng để đánh giá xem chúng có thực sự nguy hiểm hay không. Những tính năng này thường là các phần tử của trang web yêu cầu sự tương tác với người dùng.
- Việc tìm kiếm các phần tử tương tác của trang web có thể dễ dàng như việc phát hiện một biểu mẫu đăng nhập hoặc đơn giản hơn là xem xét thủ công mã Javascript của trang web.

Một ví dụ về việc xem xét trang web của Acme IT Support sẽ trông như thế này:

Feature	URL	Summary
Home page	/	Trang này tóm tắt các hoạt động của Acme IT Support, kèm theo ảnh công ty và đội ngũ nhân viên.
Latest News	/news	Trang này chứa danh sách các bài báo mới được công ty đăng tải gần đây, và mỗi bài báo đều có một liên kết kèm theo mã số định danh, ví dụ: /news/article?id=1
News Article	/news/article?id=1	Hiển thị từng bài báo riêng lẻ. Một số bài báo dường như bị chặn và chỉ dành cho khách hàng cao cấp.
Contact Page	/contact	Trang này chứa một biểu mẫu để khách hàng liên hệ với công ty. Biểu mẫu bao gồm các trường nhập tên, email và tin nhắn, cùng với nút gửi.
Customers	/customers	Liên kết này chuyển hướng đến /customers/login.
Customer Login	/customers/login	Trang này chứa một biểu mẫu đăng nhập với các trường tên người dùng và mật khẩu.
Customer Signup	/customers/signup	Trang này chứa một biểu mẫu đăng ký người dùng bao gồm các trường nhập liệu: tên người dùng, email, mật khẩu và xác nhận mật khẩu.
Customer Reset Password	/customers/reset	Biểu mẫu đặt lại mật khẩu có ô nhập địa chỉ email.
Customer Dashboard	/customers	Trang này chứa danh sách các yêu cầu hỗ trợ CNTT mà người dùng đã gửi và nút "Tạo yêu cầu hỗ trợ".

Create Ticket	/customers/ticket/new	Trang này chứa một biểu mẫu với ô nhập liệu để ghi lại sự cố CNTT và tùy chọn tải lên tệp để tạo phiếu hỗ trợ CNTT.
Customer Account	/customers/account	Trang này cho phép người dùng chỉnh sửa tên người dùng, email và mật khẩu của họ.
Customer Logout	/customer/logout	Liên kết này sẽ đăng xuất người dùng khỏi khu vực khách hàng.

2. Xem mã nguồn (viewing the page source)

- Mã nguồn trang là đoạn mã mà con người có thể đọc được, được máy chủ web trả về trình duyệt/máy khách của chúng ta mỗi khi chúng ta thực hiện một yêu cầu.
- Mã được trả về bao gồm HTML (Ngôn ngữ đánh dấu siêu văn bản), CSS (Bảng định kiểu xếp tầng) và JavaScript, và chính nó cho trình duyệt biết nội dung nào cần hiển thị, cách hiển thị và thêm yếu tố tương tác bằng JavaScript.
- Đối với mục đích của chúng ta, việc xem mã nguồn trang có thể giúp chúng ta khám phá thêm thông tin về ứng dụng web.

Làm thế nào để xem mã nguồn trang ?

- Khi xem một trang web, bạn có thể nhấp chuột phải vào trang đó, và bạn sẽ thấy một tùy chọn trên menu có nội dung "Xem mã nguồn trang".

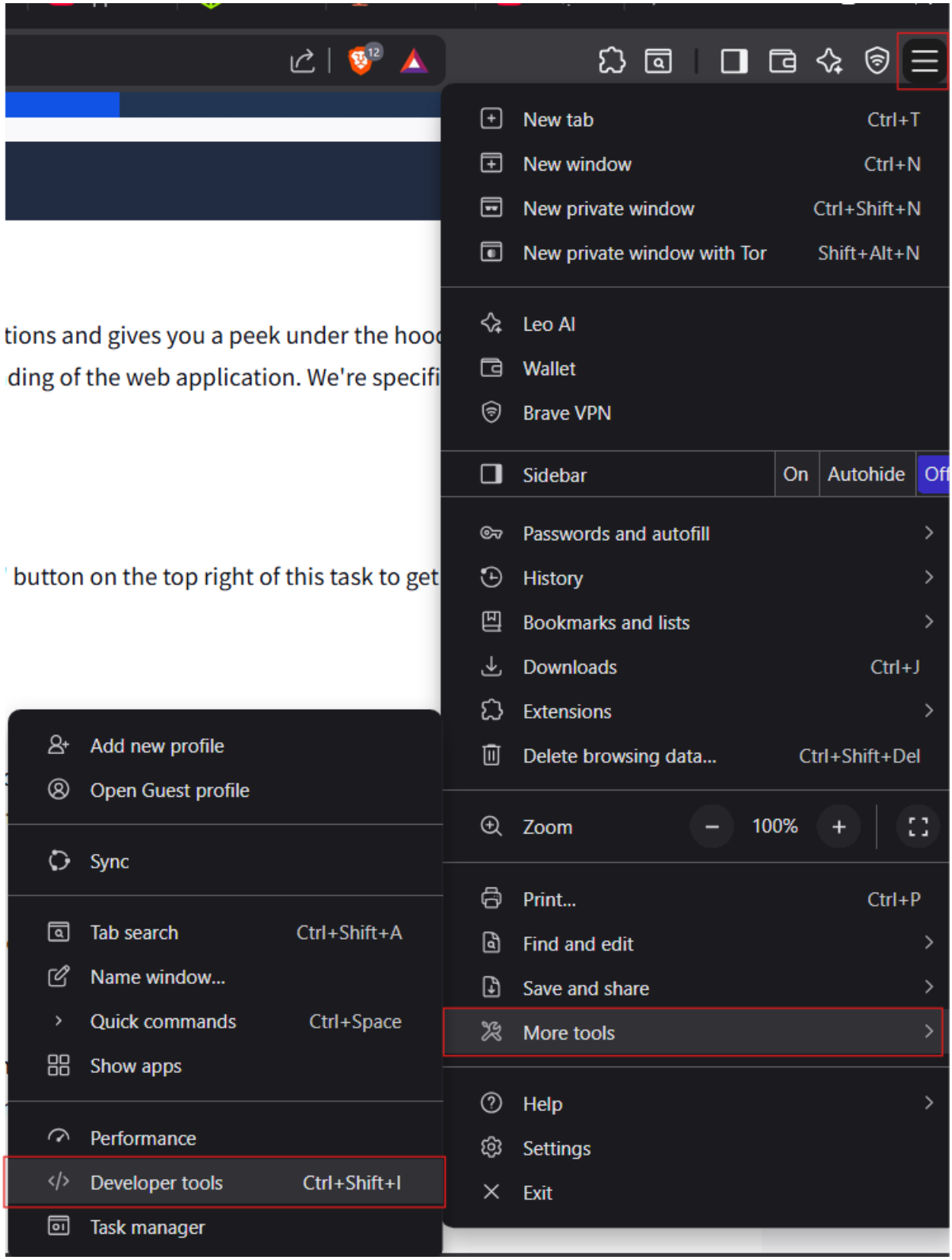
Giờ chúng ta sẽ cùng xem mã nguồn trang “Acme IT Support”.

- Ở đầu trang, bạn sẽ thấy một đoạn mã bắt đầu bằng <!-- và kết thúc bằng -->, đây là các chú thích. Chú thích là những thông báo do nhà phát triển website để lại, thường là để giải thích điều gì đó trong mã cho các lập trình viên khác hoặc thậm chí là ghi chú/nhắc nhở cho chính họ. Những chú thích này không được hiển thị trên trang web thực tế. Chú thích này mô tả cách trang chủ chỉ là tạm thời trong khi trang chủ mới đang được phát triển.
- Các liên kết đến các trang khác nhau trong HTML được viết trong thẻ neo (đây là các phần tử HTML bắt đầu bằng <a>), và liên kết mà bạn sẽ được chuyển hướng đến được lưu trữ trong thuộc tính href.
- Ví dụ, bạn sẽ thấy liên kết trang liên hệ ở dòng 31:

```
                <span class="icon-bar"></span>
                <span class="icon-bar"></span>
            </button>
            <a class="navbar-brand" href="#">Acme IT Support</a>
        </div>
        <div id="navbar" class="collapse navbar-collapse">
            <ul class="nav navbar-nav">
                <li class="active"><a href="/">Home</a></li>
                <li><a href="/news">News</a></li>
                <li><a href="/contact">Contact</a></li>
                <li><a href="/customers">Customers</a></li>
            </ul>
        </div><!--/.nav-collapse -->
```

3. Developer Tools – Inspector

Cách truy cập công cụ dành cho nhà phát triển khác nhau tùy thuộc vào trình duyệt. Để mở, ta làm như sau:


New tab Ctrl+T
New window Ctrl+N
New private window Ctrl+Shift+N
New private window with Tor Shift+Alt+N
Leo AI
Wallet
Brave VPN
Sidebar On Autohide Off
Passwords and autofill
History
Bookmarks and lists
Downloads Ctrl+J
Extensions
Delete browsing data... Ctrl+Shift+Del
Zoom 100%
Print... Ctrl+P
Find and edit
Save and share
More tools
Help
Settings
Exit
Add new profile
Open Guest profile
Sync
Tab search Ctrl+Shift+A
Name window...
Quick commands Ctrl+Space
Show apps
Performance
Developer tools Ctrl+Shift+I
Task manager
tions and gives you a peek under the hoo
ding of the web application. We're specifi
button on the top right of this task to get

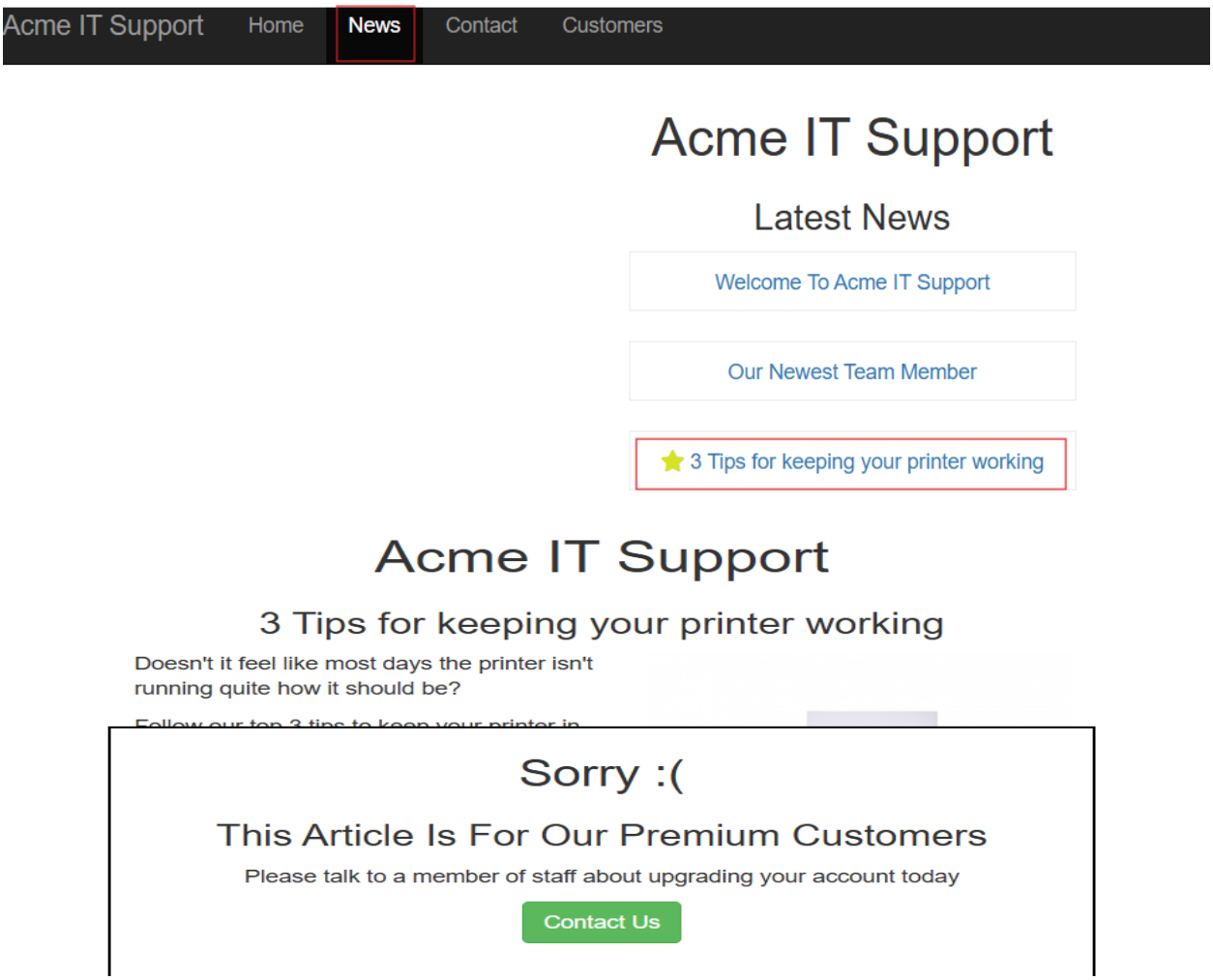
Inspector

Mã nguồn trang không phải lúc nào cũng phản ánh chính xác những gì hiển thị trên trang web; điều này là do CSS, JavaScript và tương tác của người dùng có thể thay đổi nội dung và kiểu dáng của trang, có nghĩa là chúng ta cần một cách để xem những gì đã được hiển thị trong cửa sổ trình duyệt tại thời điểm chính xác này. Trình kiểm tra phần tử hỗ trợ chúng ta bằng cách cung cấp cho chúng ta một hình ảnh trực tiếp về những gì hiện đang có trên trang web.

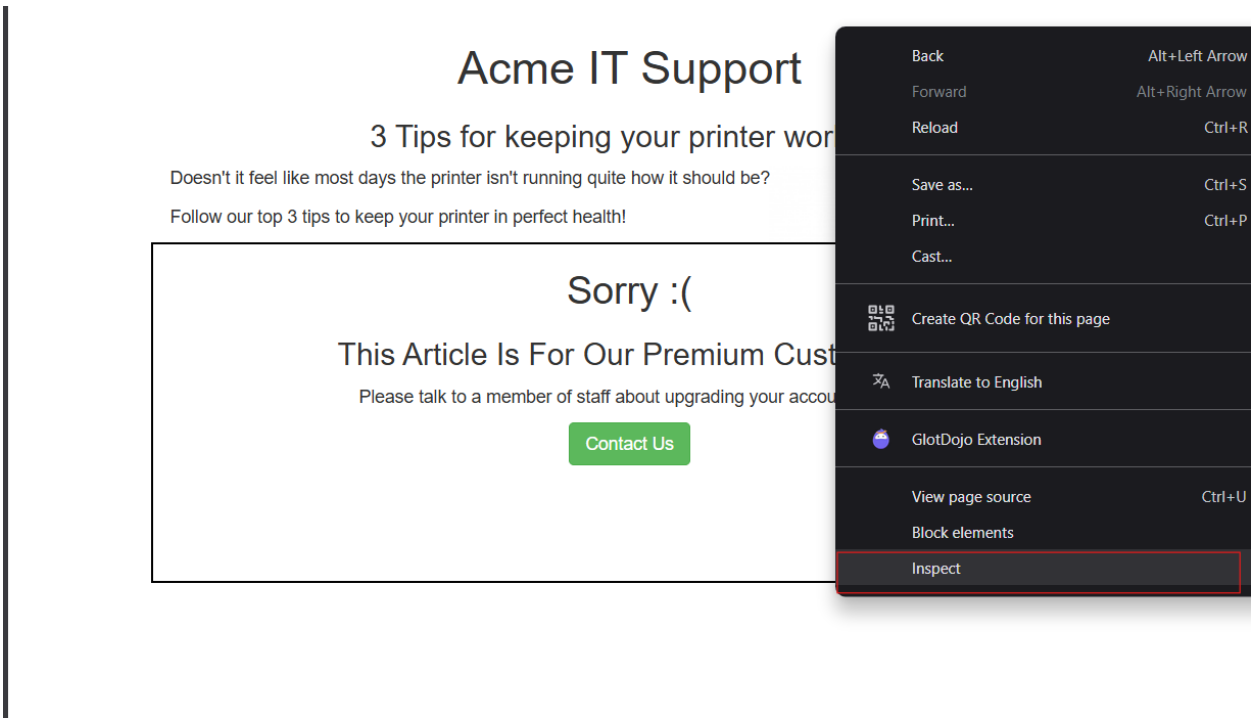
Ngoài việc xem hình ảnh trực tiếp này, chúng ta cũng có thể chỉnh sửa và tương tác với các phần tử trên trang, điều này rất hữu ích cho các nhà phát triển web trong việc gỡ lỗi.

Trên trang web Acme IT Support, hãy nhấp vào mục News, nơi bạn sẽ thấy ba bài báo.

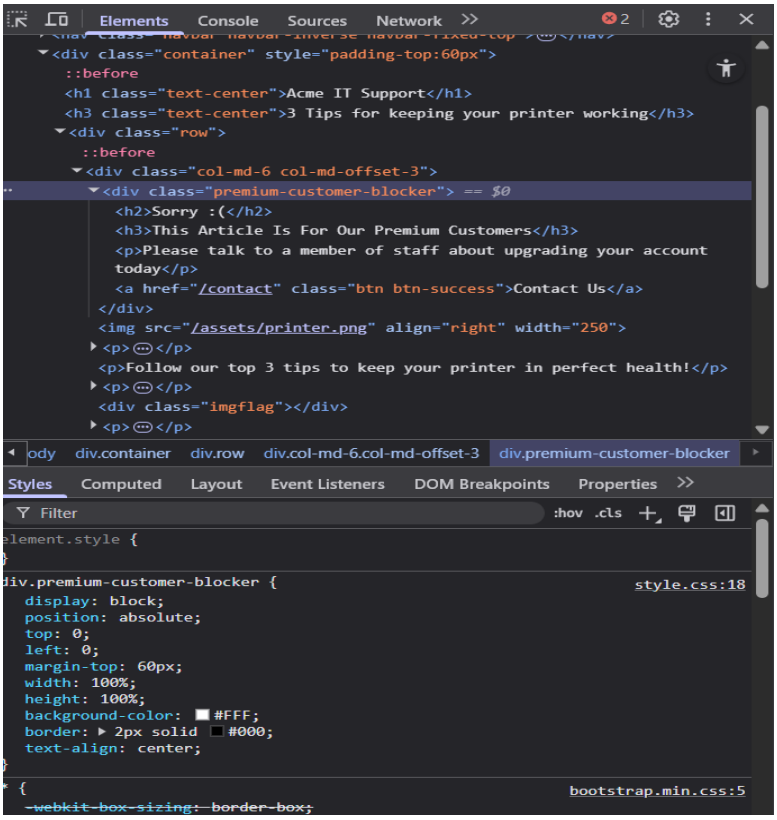
Hai bài báo đầu tiên có thể đọc được, nhưng bài thứ ba đã bị chặn bởi một thông báo nổi phía trên nội dung cho biết bạn phải là khách hàng cao cấp mới có thể xem bài báo. Những hộp nổi chặn nội dung trang này thường được gọi là tường phí vì chúng tạo ra một bức tường ẩn dụ trước nội dung bạn muốn xem cho đến khi bạn trả tiền.



Nhấp chuột phải, chọn “Inspect”.



Ta quan sát thấy các phần tử HTML tạo nên trang web như bên dưới:



Tìm phần tử DIV có lớp `premium-customer-blocker` và nhấp vào nó. Bạn sẽ thấy tất cả các kiểu CSS trong hộp kiểu áp dụng cho phần tử này, chẳng hạn như `margin-top: 60px` và `text-align:

center` . Kiểu chúng ta quan tâm là `display: block` . Nếu bạn nhấp vào chữ `block` , bạn có thể nhập giá trị tùy ý. Hãy thử nhập `none` , và điều này sẽ làm cho hộp biến mất, hiển thị nội dung bên dưới và một lá cờ.

```
div.premium-customer-blocker {
  display: NONE;
  position: absolute;
  top: 0;
  left: 0;
  margin-top: 60px;
  width: 100%;
  height: 100%;
  background-color: #FFF;
  border: 2px solid #000;
  text-align: center;
}
* {
  -webkit-box-sizing: border-box;
  -moz-box-sizing: border-box;
```

Sau khi nhập “None”, ta được flag đang tìm.

Acme IT Support

3 Tips for keeping your printer working

Doesn't it feel like most days the printer isn't running quite how it should be?

Follow our top 3 tips to keep your printer in perfect health!

Printer Jam People wrongly assume this means there's some paper stuck somewhere in the printer. In fact your printer is running low on jam! Make sure you keep the jam reservoir topped up at all times, strawberry is best and in an emergency you can use honey.

THM{NOT_SO_HIDDEN}

Paper Jam Unlike Printer Jam this is when paper is actually stuck in the printer, usually a karate chop to the paper feed tray will fix this.

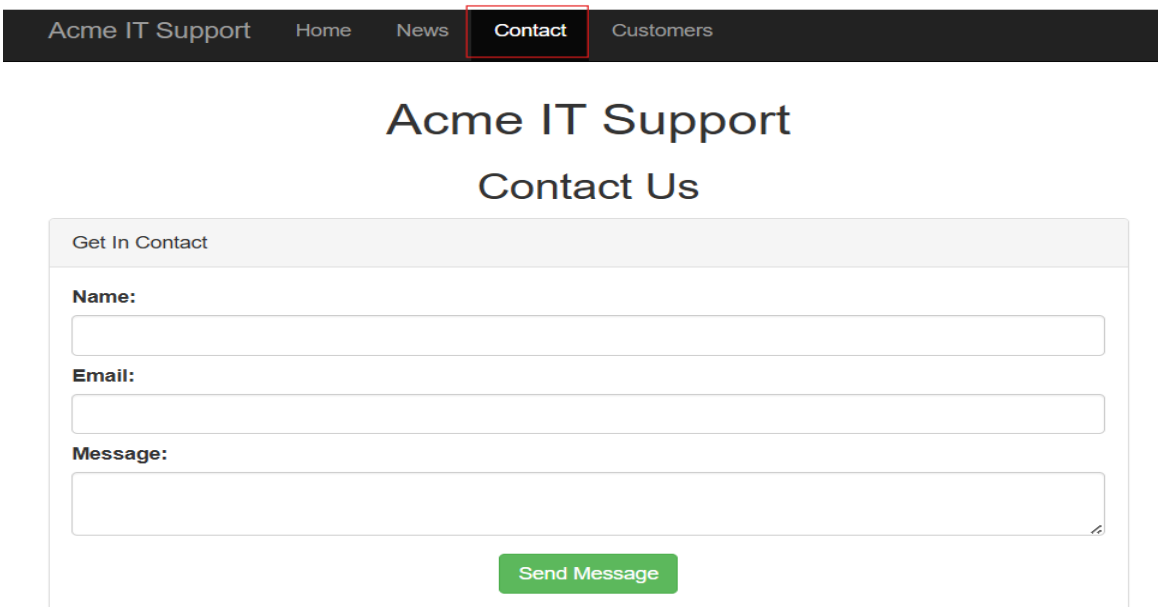
PC LOAD LETTER No one knows what this message means but your printers broken, time to take it out into a field and return it to nature.

What is the flag behind the paywall?

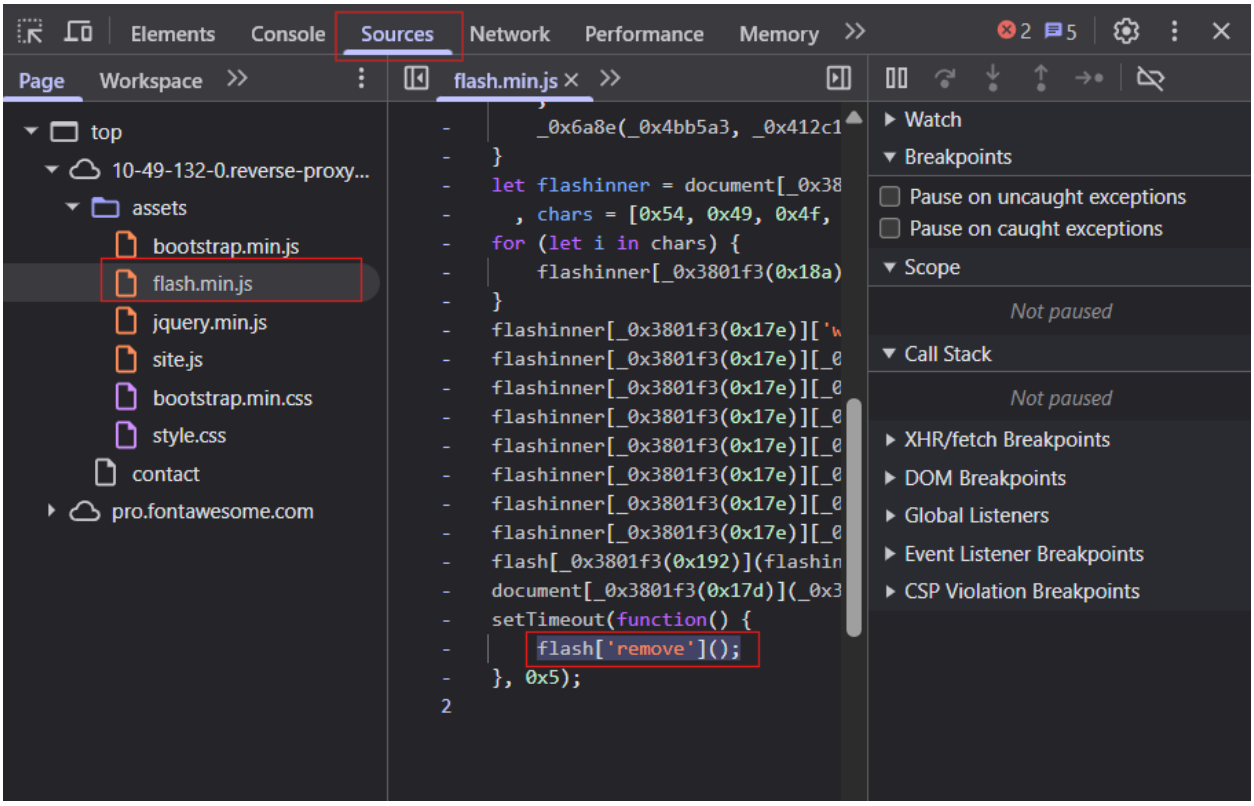
THM{NOT_SO_HIDDEN} ✓ Correct Answer

4. Developer Tools – Debugger

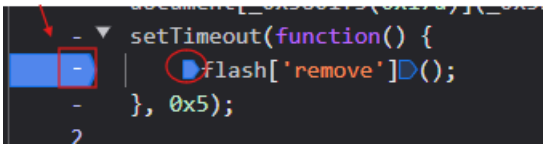
- Bảng điều khiển này trong công cụ dành cho nhà phát triển được thiết kế để gỡ lỗi JavaScript đây là một tính năng dành cho các nhà phát triển web muốn tìm hiểu lý do tại sao một thứ gì đó có thể không hoạt động. Nhưng đối với những người kiểm thử xâm nhập, nó cho phép chúng ta tìm hiểu sâu hơn vào mã JavaScript. Trong Firefox và Safari, tính năng này được gọi là Trình gỡ lỗi (Debugger), nhưng trong Google Chrome, nó được gọi là Mã nguồn (Sources).



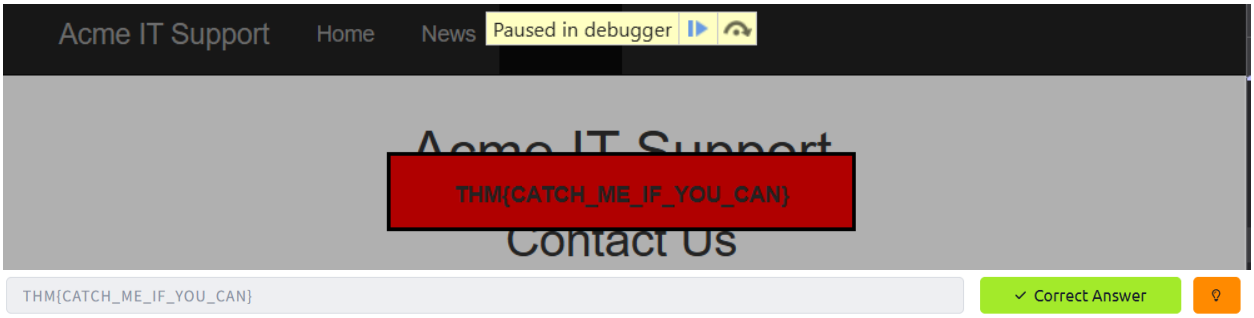
- Trên trang web của Acme IT Support, hãy nhấp vào trang liên hệ, mỗi khi trang được tải, bạn có thể nhận thấy một chấm đỏ nhấp nháy nhanh trên màn hình. Chúng ta sẽ sử dụng Trình gỡ lỗi để tìm hiểu xem chấm đỏ này là gì và liệu nó có chứa bất kỳ thông tin thú vị nào hay không. Gỡ lỗi một chấm đỏ không phải là điều mà chúng ta sẽ làm trong thực tế với tư cách là một người kiểm thử xâm nhập, nhưng nó cho phép chúng ta sử dụng tính năng này và làm quen với Trình gỡ lỗi.
- Ở phía bên phải, ta thấy danh sách tất cả các tài nguyên mà trang web hiện tại đang sử dụng. Nếu ta nhấp vào thư mục assets, ta sẽ thấy một tệp có tên flash.min.js. Nhấp vào tệp này sẽ hiển thị nội dung của tệp JavaScript.



- Đoạn mã JavaScript nhỏ này chính là thứ giúp loại bỏ cửa sổ bật lên màu đỏ khỏi trang. Chúng ta có thể sử dụng một tính năng khác của trình gỡ lỗi gọi là điểm dừng (breakpoint). Đây là những điểm trong mã mà chúng ta có thể buộc trình duyệt ngừng xử lý JavaScript và tạm dừng quá trình thực thi hiện tại.
- Nếu ta nhấp vào số dòng chứa đoạn mã trên, ta sẽ thấy nó chuyển sang màu xanh lam; bạn đã đặt một điểm dừng trên dòng này. Bây giờ hãy thử làm mới trang, và ta sẽ thấy hộp màu đỏ vẫn còn trên trang thay vì biến mất, và nó chứa một flag.

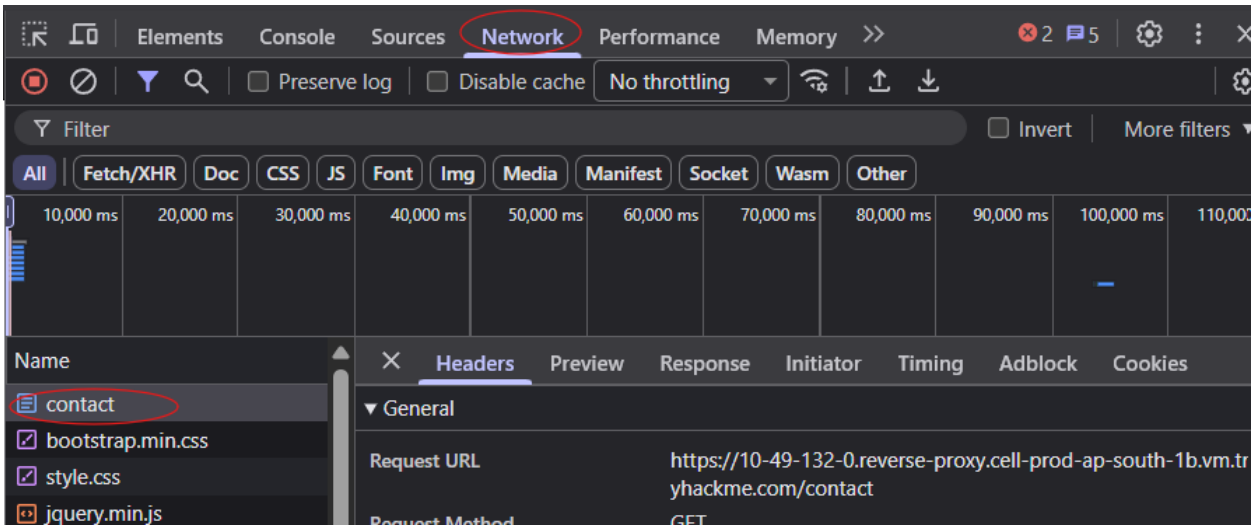


Ta tìm được flag.



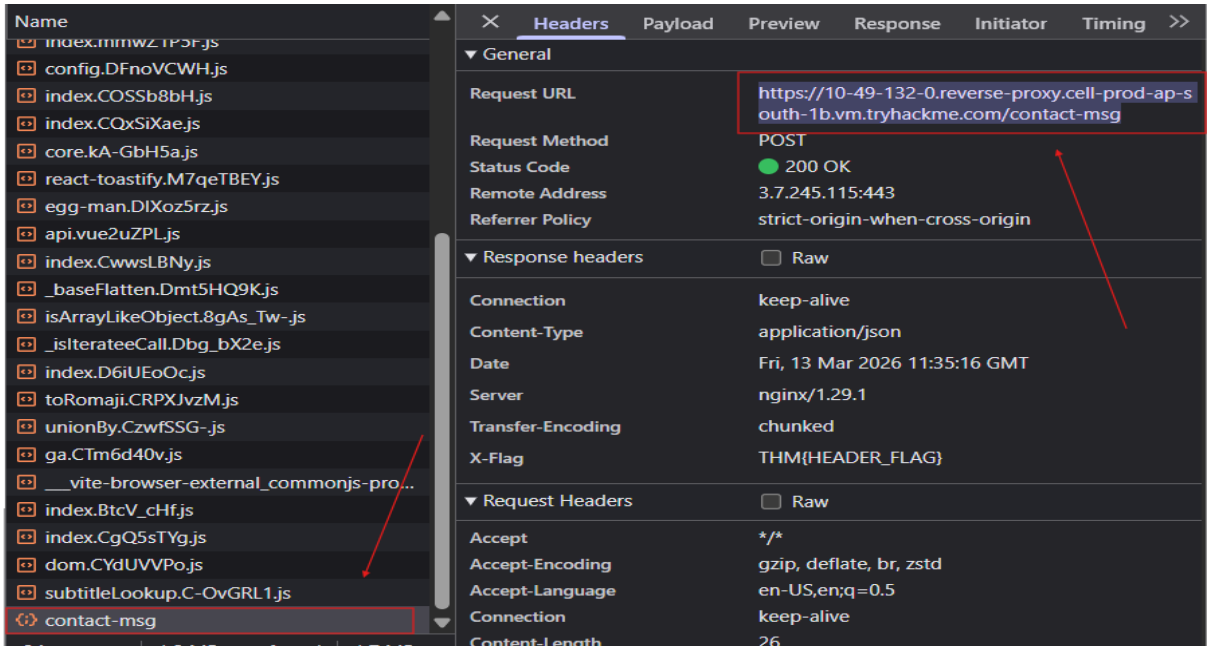
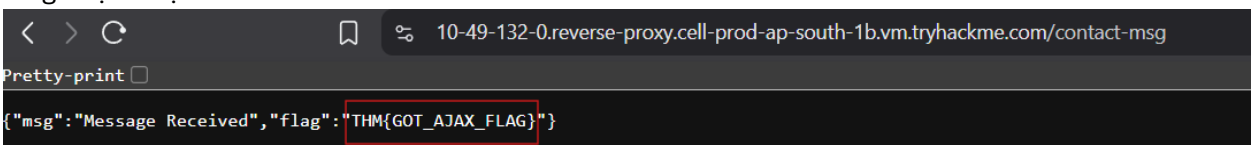
5. Developer Tools – Network

- Tab Network trong công cụ dành cho nhà phát triển có thể được sử dụng để theo dõi mọi yêu cầu bên ngoài mà một trang web thực hiện. Nếu ta nhấp vào tab Mạng và sau đó làm mới trang, ta sẽ thấy tất cả các tệp mà trang đang yêu cầu.
- Với tab network đang mở, hãy thử điền vào biểu mẫu liên hệ và nhấn nút Gửi tin nhắn. Ta sẽ thấy một sự kiện trong tab Mạng, và đây là biểu mẫu đang được gửi trong nền bằng phương pháp AJAX. AJAX là một phương pháp để gửi và nhận dữ liệu mạng trong nền ứng dụng web mà không can thiệp bằng cách thay đổi trang web hiện tại.



Kiểm tra mục mới được tạo trên tab Network bởi biểu mẫu liên hệ và xem trang mà dữ liệu đã được gửi đến để phát hiện flag.

Ta truy cập theo đường link:



- Flag nhận được: